

Maturity Assessment Using the NIST Cybersecurity Framework (CSF)

Key Areas of Improvements:

Cyber Security Governance:

- Hire a Cyber Security Manager or Chief Information Security Officer (CISO)
- Formalize cyber security roles and responsibilities and ensure board-level accountability
- Draft and implement a comprehensive information security policy approved by senior management
- Establish a cyber security governance committee for oversight and decision-making
- Invest in hiring cyber security professionals to establish and manage a cyber security practice

Cyber Security Risk Management:

- Establish a formal cyber security risk management framework aligned to NIST
- Create and maintain a cyber security risk register
- Prioritize risks based on likelihood and business impact
- Ensure regular reporting to senior management and the audit/risk committee
- Integrate cyber security into the enterprise risk management program
- Recommend including cyber security within the internal audit program

Asset Management:

- Identify and maintain an inventory of all assets (hardware, software, data)
- Classify assets based on criticality and sensitivity
- Implement and maintain an accurate CMDB
- Conduct periodic reviews to ensure asset inventory remains up to date
- Identify and manage unauthorised or shadow IT assets

Identity and Access Management:

- Implement and enforce multi-factor authentication (MFA) across the organization
- Enforce least privilege and segregation of duties
- Eliminate shared accounts and implement role-based access control (RBAC)
- Conduct regular user access reviews
- Implement Privileged Access Management (PAM) for administrative accounts

Data Security and DLP:

- Conduct a data discovery and classification exercise
- Label sensitive data using Microsoft Azure Information Protection (AIP)
- Implement a Data Loss Prevention (DLP) solution (preferably Microsoft-based)

- Restrict and monitor USB/removable media usage
- Encrypt sensitive data at rest and in transit

Vulnerability and Patch Management:

- Establish a formal vulnerability management program
- Conduct regular authenticated vulnerability scans
- Prioritise remediation based on risk severity
- Apply security patches within defined timelines (e.g., critical within 7–14 days)
- Track and report remediation metrics

Detection and Response:

- Invest in a SIEM solution (via MSSP or in-house) for real-time monitoring
- Establish 24/7 security monitoring capability
- Develop an enterprise-wide incident response plan
- Create incident response playbooks for common attack types
- Conduct regular incident response testing (tabletop exercises)

Third Party Risk Management:

- Establish a formal third-party risk management framework
- Identify and classify suppliers based on risk level
- Perform security assessments before onboarding vendors
- Conduct periodic reviews of critical suppliers
- Include security requirements in contracts and SLAs

Security Education and Awareness:

- Conduct mandatory security awareness training annually
- Run simulated phishing campaigns
- Provide role-based training for high-risk users
- Track and report training effectiveness
- Promote a strong security culture across the organisation